

Recruitment Agency DPDPA Starter Checklist

Your agency doesn't just forward CVs — it moves candidate data across clients, tools and teams. Work through these ten areas to bring candidate sourcing, CV sharing, identity documents, ATS access and rejected-candidate retention under DPDPA-ready control.

CVs

Candidate Consent

Job Portals

ATS

WhatsApp

Client Sharing

BGV

Salary Slips

Rejected Profiles

AI Screening

How to use this: tick what you already do, and turn the unticked boxes into your next actions. Start with sourcing notice, CV sharing and rejected-candidate retention — they remove the most risk for the least effort.

1 Candidate sourcing & notice

- ☐ List the channels you actually source from (portals, LinkedIn, referrals, walk-ins, reused databases, client lists).
- ☐ Avoid scraping or buying candidate lists without a lawful basis and a clear notice.
- ☐ Give every candidate a short notice: what you collect, why, who you share it with, and how long you keep it.
- ☐ Capture sourcing consent at the point of first contact — not verbally after the fact.
- ☐ Maintain one primary candidate record so you always know what you hold and where.

2 CV sharing with clients

- ☐ Share only relevant, shortlisted profiles — not bulk CV folders.
- ☐ Confirm candidate consent before forwarding a CV to a specific client.
- ☐ Prefer a controlled ATS/client portal over email/WhatsApp attachments.
- ☐ Tell clients in writing how they may use and retain the CVs you share.
- ☐ Keep a log of which candidate was shared with which client, and when.

3 PAN / Aadhaar / salary / BGV documents

- ☐ Collect identity, salary and BGV documents only after shortlist/offer — and only when needed.
- ☐ Prefer masked Aadhaar where possible; avoid collecting full ID at registration.
- ☐ Store these documents in access-controlled storage, not inboxes or laptops.
- ☐ Restrict who can open salary, bank and BGV files to staff who need them.
- ☐ Delete identity/verification copies once the purpose is complete.

4 **ATS & candidate database access**

- ☐ Use an ATS/CRM with role-based access as the single source of truth.
- ☐ Give each recruiter access only to the mandates they work on.
- ☐ Turn on MFA for every account that can open candidate records.
- ☐ Review who has access to the candidate database at least twice a year.
- ☐ Avoid duplicate copies of the database in spreadsheets and personal drives.

5 **WhatsApp / email / Excel tracker risk**

- ☐ Avoid using WhatsApp groups to circulate CVs or candidate details.
- ☐ Move candidate data off WhatsApp/email into controlled storage, then delete the copy.
- ☐ Replace ad-hoc Excel trackers with controlled ATS records where possible.
- ☐ Never store PAN/Aadhaar/salary documents on recruiter personal devices.
- ☐ Lock down shared Drive/Dropbox folders — no 'anyone with the link'.

6 **Client-sharing & hiring-manager access**

- ☐ Define how hiring managers receive and store the profiles you send.
- ☐ Avoid giving clients standing access to your ATS or full candidate database.
- ☐ Set expectations (or contract terms) on client-side retention and re-sharing.
- ☐ Track what happens to a CV after it is forwarded, as far as practical.
- ☐ Withdraw shared profiles when a candidate opts out or a mandate closes.

7 **Freelancer / ex-recruiter access removal**

- ☐ Give freelancers, interns and external recruiters need-based, time-bound access.
- ☐ Revoke access the same day an assignment ends or a recruiter leaves.
- ☐ Keep a record of who can access which candidate folders/trackers.
- ☐ Disable accounts and revoke device/app access on the last working day.
- ☐ Brief every joiner on candidate-data confidentiality and DPDPA basics.

8 **Rejected-candidate retention**

- ☐ Set a retention period for rejected/inactive profiles (e.g. 12–24 months).
- ☐ Separate 'keep with consent for future roles' from 'delete now'.
- ☐ Schedule an annual review to archive or delete profiles past their period.
- ☐ Do not keep candidate databases 'forever' by default.
- ☐ Write down retention rules so the whole team applies them consistently.

9 Candidate correction / deletion requests

- ☐ Publish a simple way for candidates to correct, delete or withdraw their profile.
- ☐ Define who handles requests and a target response timeline.
- ☐ Verify identity before acting on a request.
- ☐ Delete across ATS, email, drives and trackers — not just the primary record.
- ☐ Log each request and what you did, as evidence of compliance.

10 AI screening & CV parsing

- ☐ List the AI tools that screen, summarise, rank or parse candidate data.
- ☐ Keep a human in the loop for shortlisting and rejection decisions.
- ☐ Disclose AI processing in your candidate notice.
- ☐ Check what each AI vendor stores and whether data is used to train models.
- ☐ Avoid pasting candidate PII into ungoverned public AI tools.